

AEGIS GUARD

Behavioral Twin Prompt Injection Firewall

ET AI Hackathon: Agentic Edition · Problem 2 · Solo · **Claim F3 / D2**

Live: <https://aegis-prompt-injection-firewall.vercel.app>

GitHub: <https://github.com/krabhi75/aegis-prompt-injection-firewall>

1. The enterprise risk

Tool-using agents read PDFs, email, HTML, and APIs. Attackers hide instructions inside those documents (indirect prompt injection) to trigger secret theft and tool abuse. Keyword classifiers are not enough.

2. Insight

Prompt injection is a **runtime security** problem: would untrusted content change the agent's tool calls? Aegis runs a behavioral twin (trusted plan vs raw plan) and blocks on high-risk drift.

3. Control plane

Ingest → Decode → Provenance → Static (9 attack types) → Behavioral Twin → Risk → Gate (ALLOW / QUARANTINE / BLOCK) → Protected agent with capability tokens · Human analyst quarantine.

4. Demo proof

Scenario	Result
Benign product PDF	ALLOW
Indirect injection in PDF	BLOCK — twin drift get_secret + send_email
Encoded HTML jailbreak	BLOCK — decode layer
Multi-step roleplay → tools	QUARANTINE / BLOCK — session risk
Analyst queue	HITL approve/deny + audit

5. Declared 9-blocker: F3 / D2

F3: All 9 official attack types implemented; demo shows ≥ 7 . **D2:** Structured/textual multimodal inputs with high reliability (corpus n=55, precision/recall/F1 $\approx$ 1.0, pytest 11/11). **Not claiming D3** (Word/image OCR not fully demonstrated).

6. Business impact

Risk reduction for Accenture clients shipping agents · Auditability (incident JSON) · OWASP LLM Top 10 / NIST AI RMF mapped · Humans in the loop.

Closer: Everyone else ships a classifier. We ship a twin. If the document tries to make your agent steal secrets, the plans diverge — and Aegis blocks before a single tool runs.